15 DE FEBRERO DE 2026

ACTIVIDAD 05:

CARTOGRAFIANDO EL PENTESTING: ANÁLISIS COMPARATIVO DE METODOLOGÍAS DE SEGURIDAD INFORMÁTICA

CNO V : SEGURIDAD INFORMÁTICA

Laura Ivon Montelongo Martínez - 177291

Introducción

La seguridad informática se ha convertido en un componente esencial para la protección de los activos digitales, la continuidad operativa y la confidencialidad de la información en organizaciones de todos los sectores. Dentro de este contexto, las pruebas de penetración y las evaluaciones de seguridad representan herramientas clave para identificar vulnerabilidades, medir el nivel de exposición a amenazas y fortalecer los controles existentes. Para llevar a cabo estos procesos de manera estructurada y confiable, se han desarrollado diversas metodologías y marcos de referencia que establecen lineamientos técnicos, fases de ejecución y criterios de evaluación.

El presente análisis comparativo examina distintas metodologías reconocidas en el ámbito del pentesting y la evaluación de la seguridad informática, con el propósito de comprender sus enfoques, objetivos, alcances y contextos de aplicación. A través de la comparación de sus características principales, como: fases, orientación, organismos responsables y certificaciones asociadas, se busca desarrollar un criterio técnico que permita seleccionar la metodología más adecuada según el escenario de seguridad a evaluar.

Tabla Comparativa

Aspecto	MTRE ATT&CK	OWASP WSTG	NIST SP 800-115	OSSTMM	PTES	ISSAF
Descripción	Es una base de conocimientos universalmente accesible y actualizada para modelar, detectar, prevenir y combatir las amenazas de ciberseguridad basadas en los comportamientos adversarios conocidos de los delincuentes cibernéticos	Guía práctica para realizar pruebas de seguridad en aplicaciones web.	Guía técnica que describe las fases y técnicas para la planificación, ejecución y post-evaluación de pruebas de seguridad y evaluaciones de sistemas de información	Manual de metodología abierta que audita la seguridad operacional mediante pruebas de penetración, enfocándose en la verificación de controles y la medición precisa de la postura de seguridad a través de canales (humano, físico, inalámbrico, etc.).	Marco de trabajo técnico que guía la realización de pruebas de penetración, desde la fase inicial de pre-engagement hasta la entrega del informe final, con énfasis en aspectos técnicos detallados.	Marco de evaluación de seguridad de sistemas de información que mapea las pruebas de penetración con pasos específicos para diferentes dominios (redes, sistemas, aplicaciones), vinculando vulnerabilidades con controles y parches.
Fases de Implementación	**1.** Planificación **2.** Ejecución **3.** Mapeo **4.** Detección/Análisis	**1.** Planificación **2.** Recolección de la información **3.** Pruebas **4.** Reporte	**1.** Planificación **2.** Ejecución **3.** Post-Evaluación	**1.** Inducción **2.**Interacción **3**. Indagatoria **4.** Intervención.	**1.** Interacciones previas al compromiso **2.** Recopilación de inteligencia **3.** Modelado de amenazas **4**. Análisis de vulnerabilidades. **5.** Post-explotación y pivoting. **6.** Reporte final	**1.** Planificación y preparación. **2.** Evaluación **3.** Reporte, limpieza y soporte a remediación
Objetivo principal	Detectar y clasificar técnicas de ataque y comportamiento adversario.	Identificar vulnerabilidades de seguridad en aplicaciones web durante todo su ciclo de vida.	Evaluar controles de seguridad de forma metodológica.	Medir seguridad operativa con métricas objetivas.	Estandarizar las pruebas de penetración como un servicio.	Evaluación integral de seguridad de sistemas, redes y controles.
Escenarios en los que se utiliza	Threat hunting, SOC, Red Team, Blue Team, detección y respuesta.	Pruebas de penetración en aplicaciones web, revisiones de código, integración en pipelines de CI/CD para DevSecOps, auditorías de seguridad web.	Auditorías formales en gobierno y empresas, cumplimiento normativo, evaluaciones sistemáticas de seguridad.	Infraestructura, físico, humano, redes, telecom.	Pruebas de penetración externas e internas, evaluaciones de seguridad de redes, aplicaciones y sistemas.	Pentesting legacy, auditorías de cumplimiento organizacional, evaluaciones integrales en entornos empresariales.
Orientación	Defensa y evaluación	Evaluación	Evaluación	Evaluación	Evaluación y ataque	Evaluación.

Autores u organismos responsables	MITRE Corporation	OWASP Foundation	NIST	ISECOM	Comunidad de expertos en seguridad.	OISSG
URL del material oficial	MITRE ATT&CK®. (s. f.-b). https://attack.mitre.org/	OWASP Web Security Testing Guide | OWASP Foundation. (s. f.). https://owasp.org/www-project-web-security-testing-guide/	NIST SP 800-115 | NIST. (2025, 29 agosto). NIST. https://www.nist.gov/privacy-framework/nist-sp-800-115	ISECOM. (2010). OSSTMM 3.0 – Open Source Security Testing Methodology Manual. Institute for Security and Open Methodologies. Recuperado de https://www.isecom.org/OSSTMM.3.pdf	The Penetration Testing Execution Standard. (s. f.). http://www.pentest-standard.org/	Open Information Systems Security Group | OISSG | Legal PDF Forms. (s. f.). All New Mexico Forms. http://www.oissg.org/issaf
Existencia de certificaciones asociadas	No hay una certificación oficial de MITRE.	No propias, base fundamental para: GWAPT, OSCP, eWPT, etc.	Relacionado con certificaciones NIST / auditoría federal.	OPST, OPSA	No propias; influye en OSCP, CREST, etc.	No activas
Versión o actualizaciones vigentes	Actualización continua (matrices Enterprise, Mobile, ICS).	Estable: v4.2 En desarrollo: v5.0 (con actualizaciones significativas)	Septiembre 2008 (Final); vigente sin revisión mayor	v3 (2010, RC)	2012 (versión estable actual)	0.2.1 (2006, estable). Considerada obsoleta por muchos, aunque sus principios técnicos aún se estudian.

Conclusión

El estudio comparativo de metodologías de pruebas de penetración y evaluación de seguridad informática permite reconocer que no existe un único marco universal aplicable a todos los escenarios, sino múltiples enfoques diseñados para distintos objetivos, niveles de profundidad y contextos técnicos. Algunas metodologías se orientan principalmente a la simulación de ataques y técnicas adversarias, mientras que otras priorizan la evaluación estructurada de controles, procesos y niveles de madurez de seguridad.

Comprender las diferencias en sus fases, propósitos, organismos responsables y grado de actualización facilita una selección más informada y estratégica de la metodología a emplear en entornos profesionales.

En conjunto, estas metodologías constituyen una base sólida para ejecutar evaluaciones de seguridad de manera sistemática, reproducible y alineada con buenas prácticas, fortaleciendo la capacidad de análisis y toma de decisiones en materia de ciberseguridad.

Referencias

- ISECOM. (2010). OSSTMM 3.0 – Open Source Security Testing Methodology Manual. Institute for Security and Open Methodologies. Recuperado de https://www.isecom.org/OSSTMM.3.pdf
- MITRE ATT&CK®. (s. f.-b). https://attack.mitre.org/
- NIST SP 800-115 | NIST. (2025, 29 agosto). NIST. https://www.nist.gov/privacy-framework/nist-sp-800-115
- Open Information Systems Security Group | OISSG | Legal PDF Forms. (s. f.). All New Mexico Forms. http://www.oissg.org
- OWASP Web Security Testing Guide | OWASP Foundation. (s. f.). https://owasp.org/www-project-web-security-testing-guide/
- The Penetration Testing Execution Standard. (s. f.). http://www.pentest-standard.org/